

การเตรียมพร้อมและการตอบสนอง ต่อการโจมตีแบบ Denial-of-Service

ตีพิมพ์ครั้งแรก กันยายน 2011
ปรับปรุงล่าสุด มีนาคม 2025



Australian Government

Australian Signals Directorate

ASD AUSTRALIAN
SIGNALS
DIRECTORATE
ACSC Australian
Cyber Security
Centre



Te Tira Tiaki

Government Communications
Security Bureau



National Cyber
Security Centre

PART OF THE GCSB

คำนำ

เอกสารเผยแพร่นี้ได้รับการพัฒนาโดยหน่วยข่าวกรองสัญญาณออสเตรเลีย (Australian Signals Directorate - ASD) ด้วยความร่วมมือกับศูนย์รักษาความปลอดภัยทางไซเบอร์แห่งชาติของนิวซีแลนด์ (New Zealand's National Cyber Security Centre - NCSC-NZ) บริษัท Akamai Technologies Ltd และบริษัท Cloudflare Pty Ltd เพื่อตอบสนองต่อแนวโน้มการโจมตีแบบ Denial-of-Service (DoS) ที่เพิ่มมากขึ้นในภูมิภาคของเรา เอกสารนี้ให้คำแนะนำแก่องค์กรต่าง ๆ เกี่ยวกับแนวทางปฏิบัติที่ดีที่สุดในการบรรเทาปัญหา โดยอ้างอิงจากกลยุทธ์ด้านภัยคุกคามในปัจจุบัน เพื่อเตรียมพร้อมและตอบสนองต่อการโจมตีแบบ DoS

เราขอแนะนำให้อ่านคำแนะนำนี้ร่วมกับเอกสารเผยแพร่ของ ASD ที่ชื่อว่า [อุปกรณ์ Internet of Things](#) และ [การรักษาความปลอดภัยอุปกรณ์ Wi-Fi และเราเตอร์ของคุณ](#) เอกสารเผยแพร่เหล่านี้ ช่วยให้บุคคลทั่วไปหลีกเลี่ยงการมีส่วนร่วมสนับสนุนการโจมตีแบบ DoS โดยไม่ตั้งใจที่อาจส่งผลกระทบต่อผู้อื่นได้

การโจมตีแบบ DoS คือการโจมตีทางไซเบอร์ที่ออกแบบมา เพื่อขัดขวางหรือลดประสิทธิภาพของบริการออนไลน์ต่าง ๆ เช่น เว็บไซต์ อีเมล และบริการระบบชื่อโดเมน (DNS) โดยปฏิเสธการเข้าถึงของผู้ใช้งานที่ถูกต้องตามกฎหมาย (legitimate users) โดยทั่วไป การโจมตีลักษณะนี้จะทำได้โดยการส่งข้อมูล การเชื่อมต่อ หรือคำร้องขอไปยังบริการออนไลน์เป็นจำนวนมากอย่างท่วมท้น เพื่อครอบงำระบบและลดประสิทธิภาพของบริการจนไม่สามารถทำงานได้ตามปกติ

โดยทั่วไป การโจมตีแบบ DoS ต้องใช้ปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายจำนวนมากจึงจะประสบผลสำเร็จ การโจมตีลักษณะนี้เกิดบ่อยขึ้นเรื่อย ๆ ส่วนหนึ่งเนื่องจากจำนวนอุปกรณ์ Internet of Things (IoT) ที่ถูกบุกรุกได้ง่ายนั้นมีเพิ่มมากขึ้น เนื่องจากผู้ผลิตอุปกรณ์ IoT มักให้ความสำคัญกับประสบการณ์ของผู้ใช้งานมากกว่าการรักษาความปลอดภัยทางไซเบอร์ อุปกรณ์ที่มีช่องโหว่ความเสี่ยงจึงอาจรวมถึงของใช้ในครัวเรือนทั่วไปที่เชื่อมต่อกับอินเทอร์เน็ตได้ เช่น สมาร์ททีวี กาต้มน้ำ เครื่องดูดฝุ่น และระบบรักษาความปลอดภัย บ่อยครั้งที่ผู้ไม่ประสงค์ดีอาจบุกรุกอุปกรณ์เหล่านี้จากระยะไกล เพื่อนำไปสร้าง "บอตเน็ต (Botnet)" ของอุปกรณ์ที่ใช้สร้างปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่าย ซึ่งอาจส่งผลกระทบต่อครัวเรือนและองค์กรมีส่วนร่วมสนับสนุนโครงสร้างพื้นฐานที่เปิดโอกาสให้เกิดการโจมตีแบบ DoS โดยไม่ตั้งใจ

กิจกรรมเมื่อเร็ว ๆ นี้บ่งชี้ให้เห็นว่า เมื่อผู้ไม่ประสงค์ดีได้บุกรุกอุปกรณ์ IoT เป็นจำนวนมากแล้ว พวกเขาอาจให้เช่าหรือขายโครงสร้างพื้นฐานนี้ให้กับอาชญากรไซเบอร์และแฮกเกอร์ (Hacktivist) ซึ่งสนใจทำการโจมตีแบบ DoS กับเป้าหมายที่พวกเขาเลือกมากขึ้นเรื่อย ๆ ในกรณีส่วนใหญ่ การโจมตีแบบ DoS มักทำขึ้นเพื่อสร้างความสูญเสียต่อประสิทธิภาพการทำงานและการเงินขององค์กร หรือเพื่อดึงดูดความสนใจจากสาธารณชนไปยังสาเหตุบางประการ ตัวอย่างของกิจกรรมลักษณะนี้มีอธิบายไว้ในคำแนะนำของ ASD เรื่อง [กลุ่มผู้เชื่อมโยงกับสาธารณรัฐประชาชนจีน ซึ่งบุกรุกเราเตอร์และอุปกรณ์ IoT เพื่อใช้ในปฏิบัติการบอตเน็ต](#)

เมื่อเศรษฐกิจของเราเปลี่ยนผ่านเข้าสู่ระบบดิจิทัลมากขึ้น และจำนวนอุปกรณ์ IoT ที่ไม่มีการรักษาความปลอดภัยที่ดี ซึ่งเชื่อมต่อกับอินเทอร์เน็ตก็โตขึ้นด้วย การโจมตีแบบ DoS จึงมีแนวโน้มที่จะเพิ่มตามมาอย่างต่อเนื่อง

ผู้ไม่ประสงค์ดีจะใช้วิธีการหลากหลายรูปแบบในการขัดขวางหรือลดประสิทธิภาพของบริการออนไลน์ขององค์กร ซึ่งรวมถึง

- การส่งปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายที่ไม่พึงประสงค์จำนวนมากไปยังบริการออนไลน์ เพื่อพยายามใช้แบนด์วิดท์ของเครือข่ายที่มีอยู่ทั้งหมด
- การส่งปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายที่ปรับแต่งเฉพาะไปยังบริการออนไลน์ เพื่อพยายามใช้ทรัพยากรการประมวลผลของคอมพิวเตอร์
- การใช้คอมพิวเตอร์ อุปกรณ์ IoT หรืออุปกรณ์อื่น ๆ ที่เชื่อมต่อกับอินเทอร์เน็ตหลาย ๆ เครื่องในการส่งปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายไปยังบริการออนไลน์จากหลายทิศทางและในสัดส่วนที่ใหญ่กว่ามาก ซึ่งเป็นการโจมตีแบบ DoS ที่พบได้ทั่วไปเรียกว่า การโจมตีแบบ Distributed DoS (DDoS)
- การเข้ายึดการจดทะเบียนโดเมนหรือเซิร์ฟเวอร์ DNS ขององค์กร เพื่อพยายามเปลี่ยนเส้นทางผู้ใช้งานที่ถูกต้องตามกฎหมายให้ออกจากบริการออนไลน์ขององค์กร

องค์กรไม่สามารถหลีกเลี่ยงการตกเป็นเป้าหมายของการโจมตี DoS ได้ แต่สามารถนำมาตรการหลายประการออกใช้งาน เพื่อเตรียมพร้อมและลดผลกระทบที่อาจเกิดขึ้นได้ การเตรียมรับมือกับการโจมตีแบบ DoS ก่อนที่จะเกิดขึ้นถือเป็นกลยุทธ์ที่ดีที่สุด เพราะหากไม่มีการเตรียมตัวล่วงหน้า การตอบสนองต่อการโจมตีแบบ DoS จะทำได้ยากและไม่มีประสิทธิภาพเท่าที่ควร

แม้องค์กรจะมุ่งเน้นที่การป้องกันตนเองจากการโจมตีแบบ DoS เป็นหลัก แต่ก็ควรดำเนินการตามขั้นตอนเพื่อปกป้องไม่ให้บริการออนไลน์และอุปกรณ์ที่เชื่อมต่อกับอินเทอร์เน็ตถูกผู้ไม่ประสงค์ดีนำไปใช้ในทางที่ผิดเพื่อโจมตีบุคคลอื่นด้วย

การเตรียมรับมือกับการโจมตีแบบ DoS

ในบริบทของปริมาณการโจมตีแบบ DoS ที่กำลังเพิ่มขึ้นทั่วภูมิภาคของเรา ก่อนที่จะนำมาตรการเพื่อเตรียมรับมือกับการโจมตีแบบ DoS ออกใช้งาน องค์กรควรประเมินความต้องการทางธุรกิจเสียก่อน เพื่อพิจารณาว่าบริการออนไลน์แต่ละรายการจะต้องดำเนินการอย่างต่อเนื่องในช่วงที่เกิดการโจมตีแบบ DoS หรือไม่ หรือสามารถยอมรับการหยุดให้บริการชั่วคราวได้

หากองค์กรคุณต้องการเพิ่มความสามารถในการต้านทานการโจมตีแบบ DoS คุณควรนำมาตรการต่อไปนี้ ออกใช้งานในเชิงรุก โดยพิจารณาตามความเหมาะสมและความเป็นไปได้ ก่อนที่การโจมตีแบบ DoS จะเกิดขึ้น

- หากองค์กรคุณใช้เครือข่ายการส่งมอบเนื้อหา (Content Delivery Network - CDN) คุณควรใช้มาตรการเพิ่มเติมต่อไปนี้ โดยพิจารณาตามความเหมาะสมและความเป็นไปได้
 - พิจารณาใช้เครือข่าย CDN ที่มีฟังก์ชันการทำงานเพื่อปกป้องเว็บเซิร์ฟเวอร์ต้นทางของคุณจากการโจมตีแอปพลิเคชันและระดับเครือข่ายหลากหลายรูปแบบ – CDN บางเครือข่ายอาจรวมคุณลักษณะเหล่านี้ไว้ในส่วนหนึ่งของไฟร์วอลล์ของเว็บแอปพลิเคชันที่จุดเชื่อมต่อ (edge) ด้วย
 - หลีกเลี่ยงการเปิดเผยที่อยู่ Internet Protocol (IP) ของเว็บเซิร์ฟเวอร์ต้นทางของคุณต่อสาธารณะโดยไม่จำเป็น และตรวจสอบให้แน่ใจว่าการเชื่อมต่อกับอินเทอร์เน็ตในที่สาธารณะใด ๆ ได้รับการปกป้องจากการโจมตีแบบ DoS แล้ว
 - หลีกเลี่ยงการใช้ที่อยู่ IP สำหรับเว็บเซิร์ฟเวอร์ต้นทางของคุณ ซึ่งผู้ไม่ประสงค์ดีสามารถคาดเดาได้ เช่น ที่อยู่ IP ในชั้นเน็ตเวิร์กเดียวกันกับที่อยู่ IP ของบริการออนไลน์ของคุณที่เปิดเผยต่อสาธารณะ
 - ใช้การควบคุมการเข้าถึงเครือข่าย (เช่น ไฟร์วอลล์) เพื่อให้แน่ใจว่าเฉพาะเครือข่าย CDN และเครือข่ายการจัดการที่ได้รับอนุญาตขององค์กรคุณเท่านั้นที่สามารถเข้าถึงเว็บเซิร์ฟเวอร์ต้นทางของคุณได้
 - หากคุณต้องการปกป้องเว็บเซิร์ฟเวอร์ต้นทางของคุณในระดับที่สูงขึ้น ควรพิจารณาใช้การเชื่อมต่อเครือข่ายที่ยืดหยุ่นและหลากหลาย ซึ่งอาจรวมถึงการเชื่อมต่อผ่านเครือข่ายส่วนต่อประสานเว็บเซิร์ฟเวอร์ต้นทางกับผู้ให้บริการเครือข่าย CDN ของคุณ
 - ตั้งค่าเครือข่าย CDN เว็บเซิร์ฟเวอร์ต้นทาง และ HTTP Header ของผู้ใช้ เพื่อเพิ่มประสิทธิภาพในการแคชข้อมูลให้ได้มากที่สุด
 - หากคุณต้องการความพร้อมใช้งานในระดับที่สูงขึ้น ควรพิจารณาแยกส่วนเว็บเซิร์ฟเวอร์ต้นทางออกเป็นส่วน ๆ เพื่อให้สามารถแยกสำรองออกจากที่อยู่ IP ที่มีความเสี่ยงต่ำออกจากสำรองของที่อยู่ IP ที่มีความเสี่ยงสูง

- กำหนดให้ชัดเจนว่าฟังก์ชันการทำงานและคุณภาพบริการใดที่ผู้ใช้บริการออนไลน์ ซึ่งเป็นผู้ใช้งานที่ถูกต้องตามกฎหมายของคุณสามารถยอมรับได้ วิธีการรักษาฟังก์ชันการทำงานดังกล่าว และฟังก์ชันการทำงานใดที่ไม่จำเป็นต้องให้บริการในระหว่างที่เกิดการโจมตีแบบ DoS
- จัดหาและใช้บริการบรรเทาปัญหาการโจมตีแบบ DoS บนคลาวด์
- พิจารณาลดพื้นที่เสี่ยงต่อการโจมตีขององค์กรคุณโดย
 - การว่าจ้างผู้ให้บริการนอกองค์กรที่มีความน่าเชื่อถือในด้านบริการออนไลน์พื้นฐาน (เช่น เครือข่าย DNS) ซึ่งมีความสามารถในการรับมือกับการโจมตีแบบ DoS ได้
 - การแยกส่วนบริการออนไลน์ที่สำคัญ (เช่น อีเมล) ออกจากบริการออนไลน์อื่น ๆ ที่มีแนวโน้มจะตกเป็นเป้าหมายถูกโจมตีมากกว่า (เช่น เว็บไซต์)
 - การตรวจสอบให้แน่ใจว่าบริการบรรเทาปัญหาการโจมตีแบบ DoS อนุญาตเฉพาะปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายที่เชื่อมโยงกับพอร์ตเครือข่ายของบริการออนไลน์เท่านั้น
- หารือกับผู้ให้บริการของคุณเกี่ยวกับรายละเอียดของกลยุทธ์การป้องกันและบรรเทาปัญหาการโจมตีแบบ DoS ของพวกเขา โดยเฉพาะในด้านต่าง ๆ ต่อไปนี้
 - ความสามารถที่พิสูจน์แล้วในการต้านทานการโจมตีแบบ DoS จากทั่วโลก
 - ประวัติที่แสดงให้เห็นถึงความสามารถในการรับมือกับการโจมตีแบบ DoS และการทดสอบการโจมตีแบบ DoS ที่ได้รับอนุญาตอย่างครอบคลุม
 - ความสามารถในการบรรเทาปัญหาการโจมตีแบบ DoS โดยอัตโนมัติเกือบทุกประเภทโดยไม่ต้องมีมนุษย์มาเกี่ยวข้อง เช่น การวิเคราะห์ปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายด้วยตนเอง
 - แนวทางในการกำหนดราคาค่าบริการ เช่น ค่าบริการแบบเหมาจ่ายหรือปรับตามปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่าย และทรัพยากรการประมวลผลคอมพิวเตอร์ที่ใช้ และคุณสามารถกำหนดขีดจำกัดค่าใช้จ่ายสูงสุดได้หรือไม่
 - เกณฑ์ที่ใช้ในการแจ้งเตือนคุณหรือระงับการให้บริการออนไลน์ในระหว่างที่เกิดการโจมตีแบบ DoS
 - การดำเนินการที่ได้รับอนุมัติล่วงหน้า ซึ่งสามารถดำเนินการได้ในระหว่างที่เกิดการโจมตีแบบ DoS
 - การจัดการป้องกันการโจมตีแบบ DoS กับผู้ให้บริการต้นทาง (upstream providers)
- นำมาตรการเพื่อตรวจจับการโจมตีแบบ DoS ออกใช้ เช่น การเฝ้าระวังตามเวลาจริงและการแจ้งเตือนเกี่ยวกับความพร้อมใช้งานของระบบ ปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่าย ทรัพยากรการประมวลผลคอมพิวเตอร์ และค่าใช้จ่ายที่เกี่ยวข้อง
- จัดเตรียมเวอร์ชันเว็บไซต์สแตติก (static website) ที่ต้องการการประมวลผลและแบนด์วิดท์น้อยที่สุด เพื่อช่วยให้การบริการดำเนินต่อไปได้ในช่วงที่เกิดการโจมตีแบบ DoS
- จัดหาและใช้งานบริการออนไลน์ที่มีความยืดหยุ่นสูง มีแบนด์วิดท์ขนาดใหญ่ มีทรัพยากรการประมวลผลคอมพิวเตอร์ที่เพียงพอ มีตำแหน่งโฮสติ้งที่กระจายตามพื้นที่ทางภูมิศาสตร์ และมีการกรองปริมาณข้อมูลที่ไหลเวียนผ่านคลาวด์ เพื่อตัดปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายที่ไม่ต้องการออก — โดยทั่วไปแล้วจะรวมถึงการใช้เครือข่าย CDN ที่มีชื่อเสียง เพื่อแคชเนื้อหาเว็บไซต์แบบคงที่และปกป้องเว็บเซิร์ฟเวอร์ต้นทางของคุณจากปริมาณข้อมูลที่ไหลเวียนผ่านเครือข่ายที่ไม่พึงประสงค์
- ปกป้องชื่อโดเมนขององค์กรคุณโดยใช้การล็อกผู้ให้บริการจดทะเบียน (registrar locking) การยืนยันว่ารายละเอียดการติดต่อของการจดทะเบียนโดเมนและรายละเอียดอื่น ๆ นั้นถูกต้อง และการปฏิบัติตามคำแนะนำเพิ่มเติมที่ระบุไว้ในเอกสารเผยแพร่ของ ASD เรื่อง [การรักษาความปลอดภัยระบบชื่อโดเมนสำหรับเจ้าของโดเมน](#)
- รักษาข้อมูลติดต่อของผู้ให้บริการของคุณให้เป็นปัจจุบัน และแบ่งปันข้อมูลติดต่อขององค์กรคุณกับพวกเขา โดยให้แน่ใจว่าข้อมูลติดต่อทั้งหมดพร้อมนำมาใช้ได้ตามความต้องการขององค์กรคุณ เช่น ตลอด 24 ชั่วโมงทุกวันตลอดสัปดาห์
- ในกรณีที่ช่องทางการสื่อสารปกติเกิดขัดข้อง จัดหาข้อมูลติดต่อสำรอง (out-of-band) ขององค์กรคุณไว้สำหรับการสื่อสารกับผู้ให้บริการผ่านช่องทางที่เชื่อถือได้
- พัฒนา นวัตกรรม และดูแลรักษาแผนตอบสนองต่อเหตุการณ์ด้านการรักษาความปลอดภัยทางไซเบอร์ โดยครอบคลุมการโจมตีแบบ DoS ในรูปแบบต่าง ๆ ที่อาจเกิดขึ้นกับบริการออนไลน์แต่ละประเภทที่ (จำเป็น) ต้องสามารถต้านทานการโจมตีดังกล่าว และฝึกใช้งานแผนดังกล่าวอย่างน้อยปีละครั้ง
- ออกแบบแอปพลิเคชันเพื่อป้องกันฟังก์ชันการทำงานที่มักถูกใช้ไปในทางที่ผิด ซึ่งใช้ทรัพยากรการประมวลผลคอมพิวเตอร์เพิ่มขึ้นหรือก่อให้เกิดค่าใช้จ่ายเพิ่มเติม (เช่น การส่งข้อความ SMS)
 - การป้องกันรวมถึงการจำกัดอัตรา (rate limiting) คำร้องขอและการตรวจสอบว่าคำร้องขอนั้นมาจากมนุษย์หรือไม่
 - ทำการทดสอบการโจมตีแบบ DoS รวมถึงการมุ่งเป้าไปที่ลำดับตรรกะที่ไม่เหมาะสมในฟังก์ชันการทำงานของแอปพลิเคชัน
 - ทำการทดสอบโหลดในวงกว้าง เพื่อระบุและแก้ไขช่องทางที่อาจถูกใช้ในการโจมตีแบบ DoS

การตอบสนองต่อการโจมตีแบบ DoS

หากองค์กรคุณยังไม่ได้เตรียมรับมือกับการโจมตีแบบ DoS คุณสามารถพยายามนำมาตรการบางส่วนที่กล่าวข้างต้นออกใช้งานในช่วงเกิดการโจมตีแบบ DoS ได้ แม้ว่ามาตรการเหล่านั้นอาจมีประสิทธิภาพน้อยกว่าและต้องใช้เวลาในการนำออกใช้ ซึ่งส่งผลให้ความสามารถในการตอบสนองขององค์กรลดลง

องค์กรคุณควรนำมาตรการต่อไปนี้ออกใช้งานในระหว่างการโจมตีแบบ DoS ตามความเหมาะสมและความเป็นไปได้ในทางปฏิบัติ

- ดำเนินการใช้แผนตอบสนองต่อเหตุการณ์ด้านการรักษาความปลอดภัยทางไซเบอร์ของคุณ
- สอบถามผู้ให้บริการของคุณว่าพวกเขาสามารถดำเนินการตอบสนองได้ทันทีหรือไม่ – หากคุณยังไม่ได้หารือเกี่ยวกับความสามารถในการตอบสนองของพวกเขามาก่อน คุณอาจพบว่าพวกเขาไม่สามารถหรือไม่เต็มใจที่จะดำเนินการดังกล่าว หรืออาจต้องการเรียกเก็บค่าธรรมเนียมเพิ่มเติม
- ระบุฟังก์ชันการทำงานที่ไม่สำคัญหรือลบเนื้อหาที่ไม่สำคัญออกจากบริการออนไลน์ของคุณที่ทำให้การโจมตีแบบ DoS ในปัจจุบันได้ผล เช่น ปรับใช้งานเว็บไซต์เวอร์ชันที่ไม่มีฟังก์ชันการค้นหา เนื้อหาไดนามิก หรือไฟล์ขนาดใหญ่
- รักษาการสื่อสารกับลูกค้าและผู้ให้บริการของคุณไว้ รวมถึงผู้ให้บริการบรรเทาปัญหาการโจมตีแบบ DoS และเฝ้าระวังความพร้อมใช้งานของบริการออนไลน์ของคุณอย่างต่อเนื่อง
- พิจารณาเปลี่ยนที่อยู่ IP ของเว็บไซต์ฟเวอร์ต้นทางของคุณ หากกำลังถูกโจมตีโดยตรง และหลีกเลี่ยงการเปิดเผยที่อยู่ IP ใหม่ต่อสาธารณะโดยไม่มีการป้องกันใด ๆ
- รายงานการโจมตีแบบ DoS ต่อหน่วยงานที่เกี่ยวข้อง รวมถึง ASD และ NCSC-NZ ตามที่ระบุไว้ในส่วน 'รายละเอียดการติดต่อ' ของเอกสารฉบับนี้

หลีกเลี่ยงการมีส่วนสนับสนุนการโจมตีแบบ DoS

องค์กรของคุณควรนำมาตรการต่อไปนี้ออกใช้ เพื่อหลีกเลี่ยงการมีส่วนสนับสนุนการโจมตีแบบ DoS โดยไม่ได้ตั้งใจ ซึ่งอาจส่งผลกระทบต่อผู้อื่นได้

- หลีกเลี่ยงการเชื่อมต่อบริการ อุปกรณ์ IoT และอุปกรณ์อื่น ๆ ซึ่งเชื่อมต่อกับอินเทอร์เน็ตที่ไม่จำเป็น ที่ตั้งค่าอย่างไม่ปลอดภัย หรือที่มีการดูแลรักษาไม่เพียงพอ
- ตั้งค่าอย่างปลอดภัย ดูแลรักษา และเฝ้าระวังบริการ อุปกรณ์ IoT และอุปกรณ์อื่น ๆ ที่เชื่อมต่อกับอินเทอร์เน็ตอย่างปลอดภัย
 - คำแนะนำเพิ่มเติมสำหรับธุรกิจขนาดเล็กมีอยู่ในเอกสารเผยแพร่ของ ASD ที่ชื่อว่า [อุปกรณ์ Internet of Things](#) และ [การรักษาความปลอดภัยอุปกรณ์ Wi-Fi และเราเตอร์ของคุณ](#)

หากองค์กรของคุณให้บริการออนไลน์ คุณควรใช้มาตรการเพิ่มเติมต่อไปนี้

- ให้ความสำคัญกับการทบทวนโปรโตคอลที่ระบุไว้ในคำแนะนำของหน่วยงานรักษาความปลอดภัยทางไซเบอร์และโครงสร้างพื้นฐาน (Cyber Security and Infrastructure Security Agency - CISA) ประเทศสหรัฐอเมริกา เรื่อง [การโจมตีแบบขยายผลที่อาศัย UDP](#)
- เฝ้าระวังช่องทางการขยายผลแบบใหม่เมื่อมีการระบุ และรักษาความปลอดภัยบริการออนไลน์ของคุณจากสิ่งเหล่านั้น
- ตั้งค่าการควบคุมการเข้าถึงเครือข่าย ทั้งขาเข้าและขาออก เพื่อจำกัดการเข้าถึงเฉพาะบริการออนไลน์และองค์กรที่ได้รับอนุญาตเท่านั้น
- ปิดกั้นการเข้าถึงของสาธารณะแบบไม่เปิดเผยตัวตนสำหรับบริการออนไลน์ที่มีความเสี่ยงต่อการนำไปขยายผล หากไม่จำเป็นต้องใช้งาน
- พิจารณาใช้กลไกการจำกัดอัตรา (rate limiting) เพื่อลดผลกระทบจากการใช้งานในทางที่ผิด หากการปิดกั้นหรือการควบคุมการเข้าถึงไม่สามารถทำได้ หรือไม่เหมาะสม

(อ่าน) ข้อมูลเพิ่มเติม

[คู่มือการรักษาความปลอดภัยข้อมูล](#) ของ ASD เป็นกรอบการทำงานด้านการรักษาความปลอดภัยทางไซเบอร์ที่องค์กรสามารถนำไปประยุกต์ใช้ได้ เพื่อปกป้องระบบและข้อมูลของตนจากภัยคุกคามทางไซเบอร์ คำแนะนำใน [กลยุทธ์เพื่อบรรเทาปัญหาของเหตุการณ์ที่เกี่ยวข้องกับการรักษาความปลอดภัยทางไซเบอร์](#) ร่วมกับคำแนะนำใน [สิ่งสำคัญทั้ง 8 ประการ](#) เป็นส่วนที่เสริมให้กรอบงานนี้สมบูรณ์ยิ่งขึ้น

[คู่มือการรักษาความปลอดภัยข้อมูลของนิวซีแลนด์](#) เป็นคู่มือของรัฐบาลนิวซีแลนด์ที่เกี่ยวกับการประกันข้อมูลและการรักษาความปลอดภัยของระบบข้อมูล ซึ่งเป็นคู่มือสำหรับผู้ปฏิบัติงานที่ออกแบบมาเพื่อตอบสนองความต้องการด้านการรักษาความปลอดภัยข้อมูลของหน่วยงานของผู้บริหาร ตลอดจน ผู้ขาย ผู้รับเหมา และที่ปรึกษาที่ให้บริการแก่หน่วยงาน

ข้อมูลเพิ่มเติมเกี่ยวกับการโจมตีแบบ DoS ประเภทต่าง ๆ มีอยู่ในเอกสารเผยแพร่ของ CISA ที่ชื่อว่า [คู่มือย่อเกี่ยวกับ DDoS](#) และ [การทำความเข้าใจและการตอบสนองต่อการโจมตีแบบ Distributed Denial-Of-Service](#)

รายละเอียดการติดต่อ

ในออสเตรเลีย หากคุณมีคำถามใด ๆ เกี่ยวกับคำแนะนำนี้ [เขียนถึง ASD](#) หรือโทร 1300 CYBER1 (1300 292 371)

ในนิวซีแลนด์ หากต้องการรายงานเหตุการณ์ที่เกี่ยวข้องกับการรักษาความปลอดภัยทางไซเบอร์ โปรดส่งอีเมลไปที่ incidents@ncsc.govt.nz หรือเยี่ยมชมหน้าเว็บของ NCSC-NZ ภายใต้หัวข้อ [รายงานเหตุการณ์](#)

ข้อจำกัดความรับผิดชอบ

เนื้อหาในคู่มือนี้มีลักษณะทั่วไปและไม่ควรยึดถือเป็นคำแนะนำทางกฎหมายหรือเป็นที่พึ่งสำหรับความช่วยเหลือในสถานการณ์เฉพาะหรือสถานการณ์ฉุกเฉินใด ๆ ในเรื่องที่สำคัญใด ๆ คุณควรขอคำแนะนำจากผู้เชี่ยวชาญอิสระที่เหมาะสมกับสถานการณ์ของตนเอง

เครือรัฐจะไม่รับผิดชอบหรือมีส่วนรับผิดชอบต่อความเสียหาย การสูญเสีย หรือค่าใช้จ่ายที่เกิดขึ้นจากการพึ่งพาข้อมูลที่มีอยู่ในคู่มือนี้

สงวนลิขสิทธิ์

© เครือรัฐออสเตรเลีย 2025

ยกเว้นตราแผ่นดิน (Coat of Arms) และกรณีที่เราเป็นนอย่างอื่น เนื้อหาทั้งหมดที่นำเสนอในเอกสารเผยแพร่นี้จัดทำขึ้นภายใต้ใบอนุญาตสากล [Creative Commons Attribution 4.0 International licence | creativecommons.org](https://creativecommons.org/licenses/by/4.0/)

เพื่อหลีกเลี่ยงข้อสงสัย ใบอนุญาตนี้ใช้ได้กับเนื้อหาตามที่ระบุไว้ในเอกสารนี้เท่านั้น



รายละเอียดของเงื่อนไขใบอนุญาตที่เกี่ยวข้องสามารถดูได้ที่เว็บไซต์ Creative Commons รวมถึงประมวลกฎหมาย [Legal Code for the CC BY 4.0 licence | creativecommons.org](https://creativecommons.org/licenses/by/4.0/)

การใช้ตราแผ่นดิน (Coat of Arms)

เงื่อนไขการใช้ตราแผ่นดินมีรายละเอียดอยู่ในเว็บไซต์ของกระทรวงนายกรัฐมนตรีและคณะรัฐมนตรีที่ [Commonwealth Coat of Arms Information and Guidelines | pmc.gov.au](https://pmc.gov.au/commonwealth-coat-of-arms-information-and-guidelines)

สำหรับข้อมูลเพิ่มเติมหรือรายงานเหตุการณ์ที่เกี่ยวข้อง
การรักษาความปลอดภัยทางไซเบอร์ ติดต่อเราที่
เว็บไซต์ cyber.gov.au | โทร 1300 CYBER1 (1300 292 371)
หมายเลขนี้มีไว้สำหรับใช้ภายในออสเตรเลียเท่านั้น